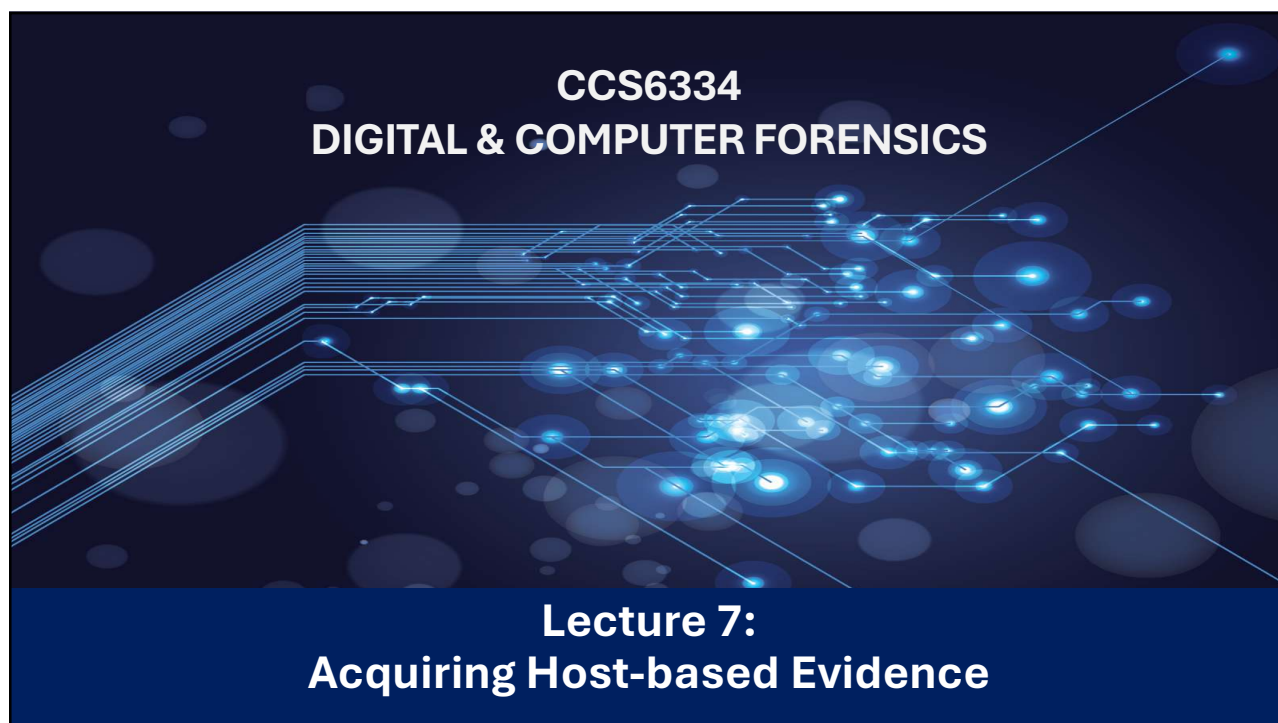




1

Learning Objectives

After studying this chapter, you should be able to:

- Explain the concept of evidence volatility and prioritize data collection based on the order of volatility.
- Describe the standard procedures for evidence acquisition and collection, ensuring integrity, authenticity, and admissibility.
- Perform and evaluate memory acquisition techniques, including capturing volatile data from live systems.
- Apply appropriate methods for remote acquisition, particularly when dealing with distributed or inaccessible devices.
- Understand and utilize virtual machines in forensic investigations, including their role in evidence preservation, testing, and analysis.

2

Host-based Evidence



- Host systems represent a possible initial target that someone can gain a foothold in the network or a pivot point for additional attacks, or create the end goal of threat actors □ basically the target of a crime/transgression
 - They can also become the source of transgressions
- Majority of these systems will be computing devices (near future might see the transition towards mobile)
- Modern OSes on these devices create a variety of evidentiary artifacts during the execution of an application, when changes to files are made, or when user accounts are added
 - All of these changes leave traces of activity that can be evaluated by incident response analysts
- As a result, incident response analysts should be prepared to acquire different types of evidence from systems for further analysis

3

Host Preparation



- Analysts should always have the necessary tools at their disposal to acquire host-based evidence
- It is critical that the tools used are those that are provided by reputable sources, have been proven effective by other CSIRT (computer security incident response team) personnel, and have been validated for efficacy prior to use.
- Incident response analysts should have a solid understanding of the types of systems that are commonly deployed similarly, should be prepared with correct tools and techniques that support the acquisition of evidence
- Permissions to devices also have to be taken into consideration, i.e.
 - Admin rights to run privileged operations on devices
 - Hidden/dummy accounts to trace operations (e.g. network attack, malicious attack) to avoid detection by attacker

4

Order of Volatility



- Volatility is used to describe how data on a host system is maintained after changes such as log-offs or power shutdowns → used to determine if live/dead recovery operations are performed on the device
- Volatile = data that will be lost if the system is powered down
 - E.g. Malware leaves a number of key pieces of evidence within the memory of a system and, if lost, can leave the incident response analyst with little or no room to investigate. This can include such artifacts as registry data, command history, and network connection
- Non-volatile = data that is stored on tertiary storage and usually persist after shutting down the device
 - E.g. majority of files, documents, configuration settings, logs are found in as non-volatile data stored in a storage device

5

EVIDENCE ACQUISITION



6

The Process of Evidence Acquisition



- There are a variety of methods that are used to not only access a potential evidence source but determine the type of acquisition that can be undertaken but they fall into the categories of:
 - Live acquisition (recovery) - analyst acquires the evidence from a system that is currently powered on and running
 - Offline (dead) acquisition - requires that the system be powered down so the storage device can be removed and specialized tools are utilized to acquire the evidence
 - Local acquisition - analysts have direct physical access to the system to perform operations necessary to collect evidence
 - Remote acquisition - analysts leverage tools and network connections to acquire evidence. Good for offsite recovery or cases with geographical challenges

7

Evidence Collection Procedures



- The following are some guidelines for proper collection of digital evidence
 - Photograph/illustrate the system and the general scene – in the event that actions that have been taken by incident responders ever see the inside of a courtroom, having photos will allow for proper reconstruction of the events
 - Determine the best type or recovery procedure to undertake (i.e. is system powered on? is data in memory important? Is leaving a system connected dangerous to the data?)
 - Acquire running memory - a critical piece of evidence that can produce a wealth of data concerning running processes, DLLs in use, and network connections
 - Acquire log/registry files - non-volatile in nature but having near-immediate access is beneficial, especially when investigating malware or other exploitation means



8

Evidence Collection Procedures (Cont.)



- Remove power source (if dead recovery is performed) – remove battery sources as well to preserve state of the system
- Photograph the back or bottom of the system to capture the model and serial number – important for records keeping and CoC
- Remove cover/casing to identify, capture/ photograph and record serial number of storage device(s) – similar reasons as above
- Removal of storage device from system and stored in anti-static bag/case
- Secure drive in evidence envelope, sealed with tamper proof tape and complete the documentation process

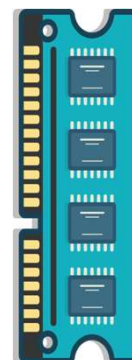


9

Acquiring Volatile Data



- As opposed to traditional criminal activity, incident responders will find that a great deal of evidence for a computer security incident is contained within the memory of a potentially compromised system
- Especially true if the incident involves malware or is an exploit running on Metasploit
- As a result, before powering down the system and removing the hard drive, it is critical that the running memory is acquired for processing
- There are several free and commercial tools that can be leveraged by incident response analysts to acquire the running memory – most popular *Volatility* and *Rekall*
- Running memory can be acquired in two ways – local or remotely



10

Local Volatile Data Acquisition



- If an analyst has physical access to a potentially compromised system, they
- have the option of acquiring the memory and other evidence locally
- To do this, tools are run from a USB device or a similar removable medium connected to the potentially compromised system to collect evidence
- It is advisable to utilize an external drive with sufficient capacity for multiple files, preferably with separate partitions for tools and the actual evidence collected
- Local acquisition is often conducted in conjunction with seizing the hard drive and other evidence from the system.
- There are several tools that are available for local acquisition – [FTK Imager](#), Google's WinPmem, Magnet ACQUIRE, and Belkasoft's RamCapturer

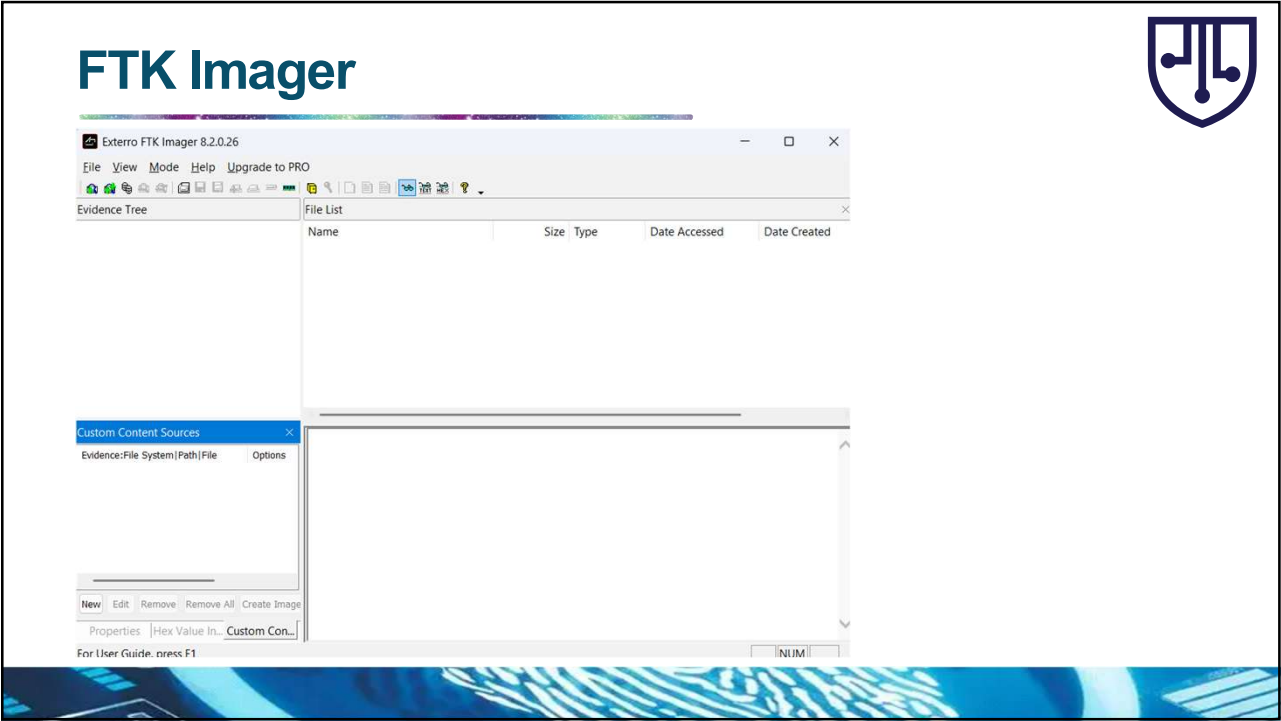
11

FTK Imager



- [FTK Imager](#) is a Windows software platform that performs a variety of imaging tasks, including acquiring the running memory of a system
- FTK Imager can also create perfect copies (forensic images) of computer data without making changes to the original evidence
- Support for hard drives, floppy disks, Zip® disks, CDs, DVDs, folders, directories, and individual files are available to image and hash/checksum
- Creates a proprietary image file AD1 that is best supported in the FTK Forensics program (commercial license) but several other forensics tools can open and access the format too (e.g. Autopsy)

12



13

Belkasoft RAM Capturer

- Another example is [RAM Capturer](#) - a simple free tool that can run from USB
- The claims of RAM Capturer is that it allows live memory dumps that can bypass anti-forensics measures like anti-dumping and anti-debugging by operating in kernel mode

14

Other Notable Tools for Volatile Recovery



- Linpmem from Rekall - <https://github.com/google/rekall> and <http://www.rekall-forensic.com/>
- Fireeye Memoryze - <https://www.fireeye.com/services/freeware/memoryze.html>
- Volatility - <https://www.volatilityfoundation.org/>

15

Remote Volatile Data Acquisition



- The preferred method for the acquisition of memory is through direct contact with the suspect system – reduce risk of contamination, able to debug errors immediately, adaptability factor should a tool not work, etc.
- Local acquisition also does not depend on extra factors like network speed, bandwidth and/or reliability of the connection
- However, due to constraints remote acquisition is sometimes the only way the data can be collected
- Analysts can often leverage the same tools that are utilized in local acquisition with the change is that analysts are required to utilize a remote technology to access the suspect systems and perform the capture.
- As with any method that is utilized, incident response analysts should ensure that they document any use of remote technology
- Example:
 - Belkasoft Remote Acquisition - <https://belkasoft.com/r>
 - Magnet AXIOM Cyber - <https://www.magnetforensics.com/products/magnet-axiom-cyber/>

16



Acquiring Non-volatile Data

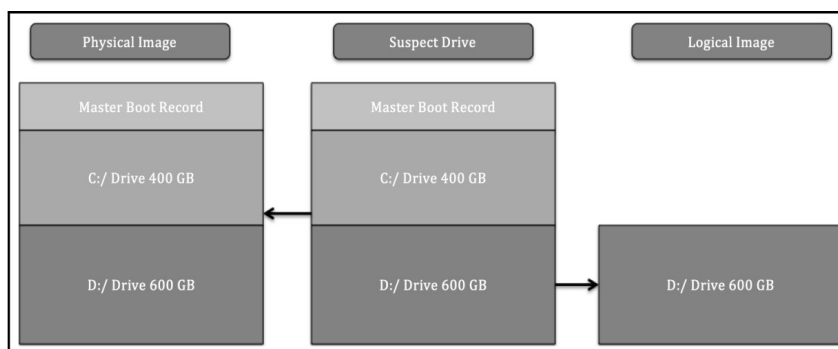
- Non-volatile data is often collected via the dead recovery process, i.e. via imaging of the storage device
- Often, the terms cloning and imaging are utilized in place of each other when it shouldn't be
 - Cloning = 1-to-1 copy of the drive content for fast recovery of systems but may leave "unimportant" data behind
 - Imaging = a bit-for-bit copy of the entire drive which is better suited for forensics should there be deleted evidence left behind
- Additionally, analysts should know the types of volume that can be imaged
- Volumes can be separated into physical or logical volumes
 - Physical volumes = containing the entirety of a hard drive
 - Logical volumes = portions of a drive possibly divided by partitions

17



Acquiring Non-volatile Data

- The choice of imaging would depend on the scenario, e.g.
 - If target evidence is known to be in a particular partition, a logical image would require far less time compared to a physical volume image
 - Encryption on disks would defeat the purpose of physical images and only a decrypted logical volume is readable/decipherable



18

Common Image File Types



- There are several types of image files, some of which are very specialized but two common ones are
- EnCase evidence file:
 - E01 or EX01 file is proprietary format from forensics tool developer EnCase. Based on Expert Witness Format (EWF), which was found in the ASR Data's Expert Witness Compression Format. The output file includes (aside from the actual image) metadata about the image, timestamps, regular checksums and image checksum for verification on data validity

File Header	64 KB Data	CRC	64 KB Data	CRC	64 KB Data	CRC	64 KB Data	CRC	MD5
-------------	------------	-----	------------	-----	------------	-----	------------	-----	-----

19

Common Image File Types (Cont.)



- Raw image
 - A raw image file contains only the data from the imaged volume. No additional data is provided in this type of image, although some imaging tools such as FTK Imager include a separate file with imaging information. Raw image outputs include the .raw, .img, and .dd extensions. Some software, such as the Linux dd command, provides a flexible option when speed and compatibility with forensic tools may be an issue
- Other possible forensics image format are the open sourced AFF4 (Advanced Forensics File Format) and AD1 (Access Data Evidence)
 - FTK tools uses the AD1 format as its output filetype
- In certain countries, the E01 file is the preferred output for law enforcement and legal entities as it combines the ability to verify evidence integrity with software features such as compression.

20

Dead Recovery/Imaging Tools (Software-based)



- While there is no court or legal body that certifies digital forensic imaging tools, there are several methods and associated tools that represent best practices when acquiring disk evidence
- FTK Imager – as previously mentioned in live recovery
- EnCase Imager – fairly similar to FTK imager with its widely accepted E01/EX01 output format
- AFF4 Imager – CLI-based tool that has a distinct feature that it can be used to carve out files based on time creation, and to slit volumes and decrease imaging time with compression
- dd (diskdump) – creates raw images of drives. Simplest tool already built into most linux OS
- VM tools – with many systems now running virtually, the target system might just be an image that can be acquired simply by pausing and copying the VM files.

21

Imaging Preparation



- Beyond having the necessary hardware and software to perform forensic imaging, it is critical to pre-stage a location to hold the image or evidence file → usually an external storage device connected via USB/Fireware/TB
- There are two tasks that need to be performed on evidence drives prior to their use (i.e. pre-staging)
- The first is to ensure that the repository is free of any data before use
- A second preparation step that can be undertaken is to encrypt the evidence drive

22

Pre-staging Drives



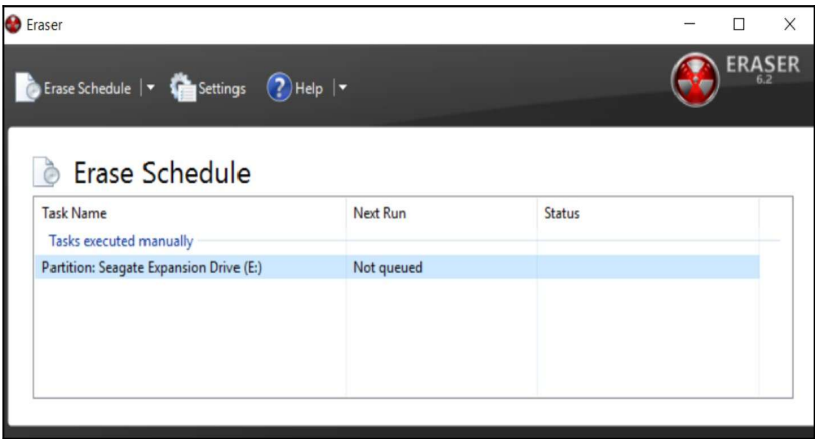
- Forensic teams should have a policy and procedure that dictate that an evidence drive be wiped prior to each use – regardless of its state or condition
- This is due to the fact that a number of manufacturers ship drives with backup software or other data that needs to be removed prior to use
- Wiping further ensures that previously utilized drives are free of any trace data from another (earlier) incident.
- This ensures that the evidence collected on to a properly wiped drive is not contaminated with unrelated data
- Some procedures also go into checking the reliability of the staged drive (via SMART reporting) before validating the drive for use
- There are existing tools available to perform these tasks for us

23

Tools for Pre-staging Drives



- Eraser by Heidi.ie



24

Tools for Pre-staging Drives (Cont.)



- DBAN (Darik's Boot and Nuke)

```
Darik's Boot and Nuke

Warning: This software irrecoverably destroys data.

This software is provided without any warranty; without even the implied
warranty of merchantability or fitness for a particular purpose. In no event
shall the software authors or contributors be liable for any damages arising
from the use of this software. This software is provided "as is".

http://www.dban.org/

* Press the F2 key to learn about DBAN.
* Press the F3 key for a list of quick commands.
* Press the F4 key to read the RAID disclaimer.
* Press the ENTER key to start DBAN in interactive mode.
* Enter autonuke at this prompt to start DBAN in automatic mode.

boot: _
```

25

Tools for Pre-staging Drives (Cont.)



- Depending on the size of the drive and the system that is performing the wipe, this process can take hours or even days – do not compare this with the format drive you see when you install Windows which is usually just a MBR clear operation
- It is recommended that analysts have several drives available and that these drives be pre-wiped before any incident to ensure if any fail, another is available on hand to complete the process,

26

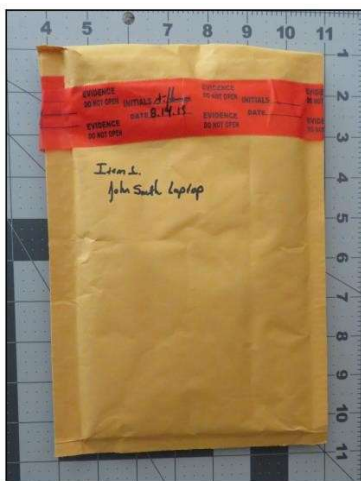
Evidence Drive Encryption



- Sometimes optional, the pre-staged drive can be encrypted to protect the data seized
- Software such as VeraCrypt or another disk encryption platform can be utilized to encrypt the partition of the evidence drive that contains the evidence files
- Analysts dealing with confidential information such as banking information, credit cards or medical records, personal information, etc. should encrypt the evidence drive, regardless of whether it leaves the facility or not
- There are two methods that can be leveraged to encrypt the evidence drive
 - Encrypt during the imaging process
 - Additional tools to encrypt the image AFTER it is acquired
- NOTE: all other security issues apply here (decryption key access, password (etc))

27

Example Process



- After photographing and documentation, storage device is collected and secured for analysis back at the lab
- Evidence collected is inspected for tampering (i.e. CoC verification) before the device is removed from storage/packaging for analysis

28

Example Process (Cont.)



- With no evidence of tampering, the drive is removed and documentation of the item proceeds
- Photographing of the device
- Serial number and model number checking and documenting
- Preparation for imaging is made – usually depending on the facilities available in the lab
 - Software/hardware write blocker
 - Pre-staged drives are readied
 - Documentation is prepared

29

Example Process (Cont.)



- Chosen operation is performed and documentation begins with photographing evidence of the operation in progress

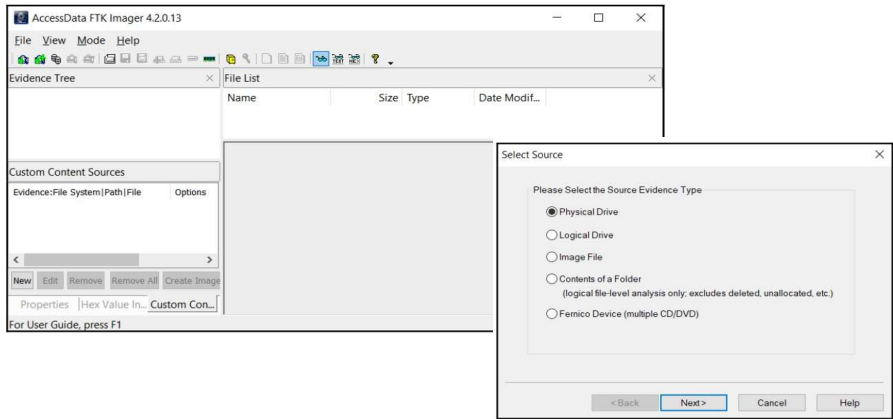


30



Example Process (Cont.)

- Some hardware devices work autonomously, whilst others work with software on a workstation – the tools used are documented for reference later

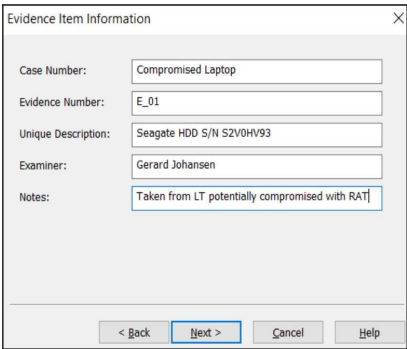
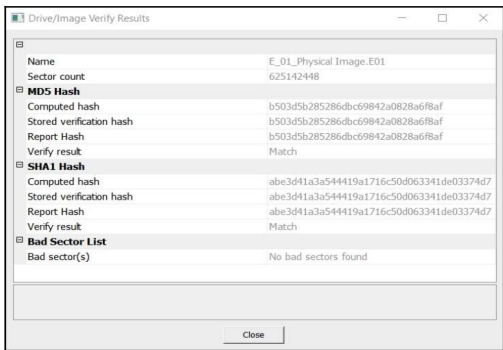


31



Example Process (Cont.)

- Information specific to the image created can be added during the imaging process (depending on tool used)



- Final generated checksums are recorded for future use in validating image authenticity and veracity

32



Summary

What was covered today:

- Host-based evidence is focused on live- and dead-recovery of data on storage medium
- For evidence to be of any use in an incident investigation, it has to be acquired in a sound manner.
- By applying solid techniques and properly documenting their actions, incident responders will be in a position to utilize the evidence to not only determine the root cause of an incident but also to back up their actions in a courtroom if necessary



Reference Source: Practical Digital Forensics (Packt Publishing)

33

THANKS – Q&A

34